

Introduction to phishing

What is phishing?

- An attack where the goal is to **trick you** into clicking a bad link or running a malicious file — usually through email
- The attacker isn't just after your password — they're after **access to the whole system**. Phishing is usually just the first step
- The weakest link in cybersecurity is not software — it's **the human being**. That's exactly what phishing exploits

Common bait phrases used

Things that should immediately raise a red flag in any email:

"You have won a gift!" | "Don't miss out on this huge discount" | "Your account will be suspended if you don't click"

These phrases create urgency and panic. Attackers want you to act before you think.

Easy way to remember it

Think of it like fishing

The attacker throws out bait (a fake email). If you "bite" (click the link), they've caught you. Phishing = fishing for victims using fake emails.

The Cyber Kill Chain — where phishing fits

Every cyberattack follows steps. Phishing is step 3 — "Delivery." Understanding the whole chain helps you see the bigger picture.

1 Reconnaissance

Attacker researches and picks their targets

2 Weaponization

Creates the malicious file or link (the weapon)

3 Delivery ← this is where phishing lives

Sends the weapon to the victim — via email, website, or USB drive

4 Exploitation

Victim clicks the link — the malicious code runs

5 Installation

Malware installs itself and creates a backdoor for later access

6 Command & Control (C2)

Attacker's outside server starts controlling the infected machine

7 Actions on objective

Attacker does what they came to do — steal data, destroy files, move to other systems

Memory hook: Recon → Weaponize → Deliver → Exploit → Install → Control → Achieve. Think: "Really Weird Dogs Eat Insects, Causing Anxiety."

Spoofing — faking who sent the email

What is email spoofing?

- Emails don't automatically verify who's sending them — so attackers can pretend to be anyone
- The email shows "From: yourbank.com" but it was actually sent from a fake server
- Even if the sender's address looks real, it might still be dangerous — the attacker could have hacked a real trusted account and is sending from it

3 protocols that fight spoofing

SPF

Sender Policy Framework. A list of approved servers allowed to send email for a domain. If the sender isn't on the list — red flag.

DKIM

DomainKeys Identified Mail. A digital signature on the email that proves it wasn't tampered with during delivery.

DMARC

Builds on SPF + DKIM. Tells the receiving email server what to do if the checks fail — reject the email, quarantine it, or just report it.

How to manually check if an email is spoofed

1

Find the [SMTP IP address](#) in the email header (the "Received" field shows you where it actually came from)

2

Go to mxtoolbox.com and look up the domain the email claims to be from

3

Compare the MX servers mxtoolbox shows vs the SMTP IP in the header. If they **don't match** — spoofed.

Important: even if SPF/DKIM pass, you still cannot assume the email is safe. Hackers can send from already-compromised legitimate email accounts — those checks will all pass.

Email headers — reading the metadata

The header is hidden information attached to every email. It tells the full story of where an email came from and how it traveled. You won't see it by default — you have to dig for it.

Key fields to know

From

Who claims to be sending it. Can be faked — don't trust this alone.

To / CC / BCC

Who received it. BCC = hidden recipients — useful to know in a mass phishing attack.

Date

Timestamp. If emails are arriving outside office hours, attacker may be in a different time zone — that's intel.

Reply-To

Where your reply actually goes. Attackers set this to their own address so replies go to them — not back to the fake sender.

Received

Every mail server the email passed through. Listed in reverse — top = last server, bottom = where it originated. Read bottom-up to trace the real path.

Message-ID

Unique ID for every single email ever sent. No two are the same.

X-Spam Status

Spam score. If it exceeds the inbox threshold, it goes to the spam folder automatically.

MIME-Version

Converts attachments (images, files) into text format so they can travel via SMTP. If an email has attachments, this field is present.

How to access the header

Gmail

Open email → 3 dots (top right) → "Download message" → open the .eml file in Notepad

Outlook

Open email → File → Info → Properties → Internet headers

Email header analysis — step by step

When you suspect a phishing email, these are the two key questions to answer in the header.

Question 1 — Did the email come from the right server?

1

Find the IP address in the **Received** field — that's the actual server it came from

2

Look at who the email claims to be from in the **From** field — note the domain (e.g. letsdefend.io)

3

Go to mxtoolbox.com and look up that domain's MX servers

4

If the IP in step 1 does NOT match the servers from step 3 — the email is **spoofed**

Real example: Email claims to be from letsdefend.io. The "Received" field shows IP 101.99.94.116. But mxtoolbox shows letsdefend.io uses Google servers. 101.99.94.116 is NOT Google. → Spoofed.

Question 2 — Do "From" and "Reply-To" match?

→ In a legitimate email, the "From" address and the "Reply-To" address should be the **same**

→ In a phishing email, attackers set "Reply-To" to their own address so your reply goes to them without you noticing

Classic scam using this trick:

Attacker impersonates a Google employee. Sends an invoice email to your company. Puts the real Google employee's email in "Reply-To." When your company replies about the invoice, the reply goes to the attacker — not Google. Company pays the fake invoice.

Note: different From and Reply-To does NOT automatically mean phishing. You need to look at the full picture — suspicious content, bad attachments, spoofed server, all together.

Static analysis — checking the email body and links

Checking URLs (links) in the email

→ Attackers use **HTML tricks** — the link you see (e.g. "click here") can point to a completely different address underneath

→ Always hover over a link before clicking — the real destination shows in the bottom of your browser

→ **New domain = major red flag**. Most phishing attacks use brand-new domain names. If the domain in the email was registered recently, be very suspicious

→ Check the URL on [VirusTotal](#) to see if antivirus engines flag it — but remember cached results can be outdated

→ Check if the URL contains your **email address as a parameter** (e.g. ?email=you@gmail.com). Even just visiting that link tells the attacker your email is real

Before visiting any link for analysis — change any personal info embedded in the URL to something fake. Otherwise just visiting it hands the attacker your data.

Checking the sender IP reputation

→ Look up the SMTP IP address in [Cisco Talos Intelligence](#) to see if it's blacklisted

→ Also check it in [VirusTotal](#) and [AbuseIPDB](#) to see if it's been involved in past attacks

→ If the SMTP IP is blacklisted → likely sent from a **compromised server** (attacker hacked someone else's server to send from)

Static vs dynamic analysis

Static analysis

Examining the file without running it. Slower. Looks at code, structure, metadata. Good for detailed inspection.

Dynamic analysis

Actually running the file or visiting the URL — but in a safe sandbox environment. Faster. Shows what the malware actually does.

Dynamic analysis — safely running suspicious content

Why you never open suspicious files on your own computer

Never run suspicious files or visit suspicious URLs on your personal/work computer

If the file is malicious, your machine gets infected. Use a sandbox — a completely isolated environment where malware can run freely but can't escape or cause real damage.

Online tools for dynamic analysis

1

Browserling

Opens a URL inside a remote browser — you're not actually visiting it on your machine. Good for quick URL checks. Can't run downloaded files though.

2

VMRay / AnyRun / JoeSandbox / Hybrid Analysis

Full sandbox environments. Upload a file and watch it run in a fake computer. Shows every change it makes — registry, network connections, files created.

Critical note: malware can detect sandbox environments and go quiet on purpose. Always run sandbox analysis for as long as possible — some malware waits 10–15 minutes before activating.

Also: no URL and no attachment does NOT mean the email is safe. Attackers sometimes hide malware inside images to avoid detection tools.

Advanced phishing tricks — attacker techniques

Attackers are getting smarter. They use normally trusted websites to avoid triggering security alerts.

1

Google Drive / Microsoft OneDrive links

Attacker uploads malware to a real cloud storage service. Sends you the link. The domain is google.com or microsoft.com — looks harmless. The actual file is malicious.

2

Free subdomains (WordPress, Wix, Blogspot)

Creates a fake phishing page at something like fakebank.wordpress.com. Whois lookup shows the domain belongs to WordPress — not the attacker. Analysts can be tricked into thinking it's safe.

3

Google Forms / free form services

Instead of building a fake login page, attacker creates a form on Google Forms to steal your info. The domain is google.com — antivirus usually allows it. Analysts see "google.com" and let their guard down.

The lesson here

A trusted domain does NOT mean trusted content. Always look at where the link is taking you and what it's asking you to do — not just who owns the domain.

How attackers find email addresses to target

→ Tool called [theHarvester](#) on Kali Linux — scrapes email addresses from public websites automatically

→ If the same users keep getting phishing emails → their addresses may have been leaked on sites like [PasteBin](#)

→ Personal recommendation: [never publicly post your email address](#) on websites — it becomes a target

Quick-reference — phishing analysis checklist

Use this every time you investigate a suspicious email.

- ★ Check the Received field — does the SMTP IP match the domain's MX servers? (use mxtoolbox)
- ★ Do From and Reply-To match? If not, replies go to the attacker
- ★ Check SPF / DKIM / DMARC records on mxtoolbox
- ★ Look up the SMTP IP on Talos Intelligence + AbuseIPDB — is it blacklisted?

- ★ Hover over all links — does the visible text match the real destination?
- ★ Check URLs on VirusTotal — force a fresh scan, never trust cached results
- ★ Is the domain new? New domain + urgent language = almost certainly phishing
- ★ Does the URL contain your email address as a parameter? Remove personal data before visiting
- ★ Run any suspicious files in a sandbox (AnyRun, JoeSandbox, VMRay) — not on your own machine
- ★ No attachment doesn't mean safe — malware can hide in images
- ★ Trusted domain (Google, Microsoft) doesn't mean trusted content